



INSTITUTO POLITÉCNICO NACIONAL

ESCUELA SUPERIOR DE CÓMPUTO



IT Governance / Gobierno de TI

8CV2

Servicio evaluado:
Servicios VPN/Firewall "Synaptic Digital"

CORTÉS VELÁZQUEZ SAMUEL ALEJANDRO

PERALTA MORENO RAFAEL

TREVIÑO HERNANDEZ JONATHAN

Índice

1. Introducción.....	3
2. Objetivo del servicio de TI.....	4
3. Descripción del servicio.....	4
4. Misión.....	4
5. Visión.....	4
6. Valores.....	4
7. Metas Corporativas (Balanced Scorecard).....	5
8. Metas de TI (COBIT).....	6
9. Cascada de metas (mapeo y relaciones primarias/secundarias).....	7
10. Mapa estratégico.....	9
11. Caso de Negocio (Formato).....	10
11.1 Información general.....	10
11.2 Antecedentes.....	10
11.3 Justificación técnica del servicio.....	10
11.4 Alcance.....	11
11.5 Objetivo.....	11
11.6 Riesgos clave.....	11
11.7 Definición de indicadores.....	11
11.8 Beneficios esperados.....	12
11.9 Planeación de alto nivel.....	12
11.10 Dependencias con otros proyectos.....	13
11.11 Personal involucrado.....	13
11.12 Justificación económica del proyecto de TI.....	13
11.12.1 Estudio de mercado.....	13
11.12.2 Costos de mantenimiento.....	14
11.12.3 Costos de operación.....	14
11.12.4 Procedimientos de adquisición.....	14
12. Cédula de Servicio (ITIL).....	14
12.1 Información general del servicio.....	14
12.2 Responsables del servicio (Matriz RACI).....	17
12.3 Roles y puntos de contacto.....	18
12.4 Condiciones generales / requisitos para proporcionar el servicio.....	19
12.5 Identificación de componentes de infraestructura.....	19
12.6 Niveles de servicio (SLA - acuerdos de servicios para los usuarios).....	20
12.7 Niveles de servicio (OLA - acuerdos operativos internos).....	21
13. Inventario de Activos.....	23
14. Matriz de Riesgos (ISO 27000) (Matriz CID, matriz de infraestructuras críticas).....	25
14.1 Infraestructuras críticas.....	26
15. BIA Táctico.....	27

15.1 BIA Táctico 1: Operación de la Red VPN y Firewall.....	27
15.2 BIA Táctico 2: Gestión de Cambios y Reglas de Seguridad.....	28
15.3 BIA Táctico 3: Monitoreo y Defensa (SOC).....	29
16. BIA Operacional.....	30
17. Plan de Continuidad.....	31
17.1 Activación y gobernanza.....	31
17.2 Estrategias por escenario.....	32
17.3 Respaldo, restauración y pruebas.....	33

1. Introducción

En el ecosistema empresarial actual, la disolución del perímetro físico tradicional ha redefinido los paradigmas de la ciberseguridad, la movilidad de la fuerza laboral y la adopción acelerada de arquitecturas en la nube exigen que el acceso a los recursos corporativos sea seguro, independientemente de la ubicación geográfica o el dispositivo utilizado.

En este contexto, la protección de la transmisión de datos y el control de accesos ya no son meros requisitos técnicos, sino pilares fundamentales para la continuidad operativa y la supervivencia del negocio, la dependencia de redes públicas para el tráfico de datos sensibles incrementa exponencialmente la superficie de ataque, haciendo imperativo que las organizaciones implementen mecanismos robustos que garanticen la privacidad y la integridad de la información sin sacrificar la agilidad que demanda la economía digital. Sin embargo, en la región de Latinoamérica, muchas organizaciones enfrentan una brecha significativa: carecen del personal especializado para gestionar infraestructuras complejas o dependen de proveedores internacionales que no ofrecen el soporte ni la adaptación normativa local necesaria, el desafío reside no solo en implementar tecnología, sino en ofrecer como un servicio gestionado que equilibre una seguridad estricta con una experiencia de usuario fluida y soporte en el idioma nativo.

Este documento desarrolla el proyecto de Synaptic Digital, una iniciativa estratégica centrada en la provisión de servicios VPN(Virtual Private Network) y firewall gestionados. La propuesta surge como una respuesta directa a la necesidad de ofrecer soluciones de "ciberseguridad de proximidad" en el corredor comercial de México, Estados Unidos y Canadá. El servicio integra la implementación de túneles cifrados a través de una VPN multiplataforma y la gestión centralizada de firewalls en la nube. Al hacerlo, Synaptic Digital busca democratizar el acceso a la seguridad de alto nivel, permitiendo que tanto usuarios individuales como clientes empresariales deleguen la complejidad técnica de la defensa perimetral.

El propósito del proyecto trasciende la mera implementación técnica; busca estructurar una empresa de servicios sostenible y confiable alineada con objetivos corporativos mediante COBIT y el enfoque del Balanced Scorecard. Estas metodologías permiten vincular la misión de Synaptic Digital —ser un socio estratégico— con objetivos de negocio medibles, traduciendo la excelencia técnica en valor empresarial tangible, como la retención de clientes y la eficiencia operativa. En paralelo, se formalizan los compromisos operativos bajo los estándares de ITIL, estableciendo una Cédula de Servicio que define alcances, niveles de servicio (SLA) y una matriz de responsabilidades clara, elementos cruciales para diferenciar el servicio por su calidad de atención. Finalmente, el diseño se fundamenta en un esquema de gestión de riesgos basado en ISO 27000, asegurando un tratamiento sistemático de las amenazas a la triada CID (confidencialidad, integridad y disponibilidad), lo cual es indispensable para que Synaptic Digital pueda operar no solo como proveedor, sino como un custodio confiable de la información crítica de sus clientes.

2. Objetivo del servicio de TI

Garantizar la confidencialidad, la integridad y la disponibilidad de las comunicaciones de red y los recursos digitales, mitigar las amenazas externas mediante la implementación de túneles cifrados (VPN) y el control perimetral gestionado (Firewall), para asegurar un acceso remoto seguro y continuo en entornos multiplataforma.

3. Descripción del servicio

El servicio proporciona una plataforma de conectividad segura y gestionada, diseñada para blindar el tránsito de información y administrar los accesos remotos a través de la implementación de controles de red avanzados, el propósito principal es garantizar la privacidad y disponibilidad de las comunicaciones corporativas, estableciendo túneles cifrados y barreras de filtrado que protejan los activos digitales ante interceptaciones, intrusiones y accesos no autorizados, tanto en redes públicas como privadas.

El servicio abarca la gestión operativa de la seguridad de forma integral, cubriendo desde el diseño y despliegue de políticas en firewalls alojados en la nube hasta la configuración de clientes VPN en entornos multiplataforma. Además, incluye el monitoreo continuo del tráfico y el mantenimiento proactivo de las reglas de seguridad, asegurando el cumplimiento normativo y una respuesta ágil ante amenazas emergentes.

4. Misión

En Synaptic Digital, nuestro propósito es empoderar a individuos y empresas a través de soluciones de ciberseguridad avanzadas, garantizando un entorno digital seguro, privado y accesible para todos.

5. Visión

Ser la marca líder en ciberseguridad en Latinoamérica, proporcionando soluciones integrales y confiables que protejan la información personal y empresarial en el entorno digital.

6. Valores

- **Integridad:** Actuamos con transparencia y honestidad en cada interacción. La confianza de nuestros clientes es nuestro activo más valioso.
- **Innovación:** Estamos en una búsqueda constante de las mejores y más nuevas tecnologías para ofrecer soluciones que no solo resuelven problemas de hoy, sino que preparan a nuestros clientes para el mañana.

- **Orientación al cliente:** Medimos nuestro éxito en función del éxito de nuestros clientes. Escuchamos, entendemos y nos alineamos completamente con sus necesidades y metas.
- **Excelencia técnica:** Nos comprometemos con los más altos estándares de calidad en cada proyecto, servicio y consulta. Nuestro equipo está en continua formación para ser el mejor en su campo.
- **Colaboración:** Fomentamos un ambiente de trabajo en equipo, tanto interno como con nuestros clientes, creyendo firmemente que las mejores soluciones surgen de la sinergia y la comunicación abierta.

7. Metas Corporativas (Balanced Scorecard)

Este es un modelo de gestión estratégica que traduce la visión y la estrategia en un conjunto de objetivos e indicadores de desempeño. Se divide en cuatro perspectivas interconectadas.

Dimensiones	Metas corporativas
Aprendizaje y Crecimiento	Capacitar al 50% del personal en 3 certificaciones (Ciberseguridad/Cloud) para el segundo trimestre de 2026
	Lograr que el 100% del personal técnico apruebe las pruebas de phishing interno y cultura DevSecOps para el primer trimestre de 2026
	Estandarizar la automatización del 80% de las tareas de primer nivel para el cuarto trimestre de 2026
Procesos Internos	Certificar 2 procesos para el segundo trimestre de 2026

	Lograr tiempo medio de resolución de incidencias críticas menor o igual a dos horas para el primer trimestre de 2026
	Entregar el 95% de los proyectos en tiempo y presupuesto para el cuarto trimestre de 2026
Cliente y Usuario	Alcanzar el 90% de satisfacción del cliente para el segundo trimestre de 2026
	Elevar el índice de recomendación del cliente a más de 60% para el cuarto trimestre de 2026
	Aumentar en 25% los clientes por recomendación para el cuarto trimestre de 2026
Financiera	Alcanzar el punto de equilibrio operativo (Break-even point) para el primer trimestre de 2026
	Aumentar los ingresos recurrentes al 60% del total para el cuarto trimestre de 2026
	Mejorar el margen bruto al 40% para el cuarto trimestre de 2026

8. Metas de TI (COBIT)

Las metas de TI alinean la estrategia de Synaptic Digital con la ejecución técnica, asegurando que la infraestructura de VPN y Firewall no solo sea segura, sino también rentable y escalable. Se priorizan la disponibilidad del servicio, la automatización de configuraciones y la eficiencia en la respuesta a incidentes.

Dimensión BSC	Meta de TI	Indicador sugerido	Meta (referencia)
Financiera	Optimizar el consumo de recursos en la nube y licencias de seguridad para maximizar el margen bruto del servicio.	Costo de infraestructura por usuario activo / % de utilización de instancias cloud	< 30% del ingreso por usuario (para apoyar el margen bruto del 40%)
Cliente/Usuario	Garantizar la alta disponibilidad y velocidad de conexión de los túneles VPN para asegurar la satisfacción del usuario final.	Disponibilidad del servicio (Uptime) / Latencia promedio de conexión	99.9% Uptime mensual; Latencia < 50ms
Procesos Internos	Estandarizar y agilizar la implementación de reglas de firewall y parches de seguridad mediante automatización.	Tiempo Medio de Resolución (MTTR) de incidentes de seguridad / % de cambios de reglas automatizados	MTTR <= 2 h (Crítico); >= 80% cambios automatizados (L1)
Aprendizaje y Crecimiento	Fortalecer las competencias técnicas en administración de redes seguras, criptografía y normatividad (ISO/NIST).	Certificaciones técnicas obtenidas por el equipo técnico / Horas de capacitación en ciberseguridad	1 certificación relevante por ingeniero al año / 100% del staff técnico capacitado

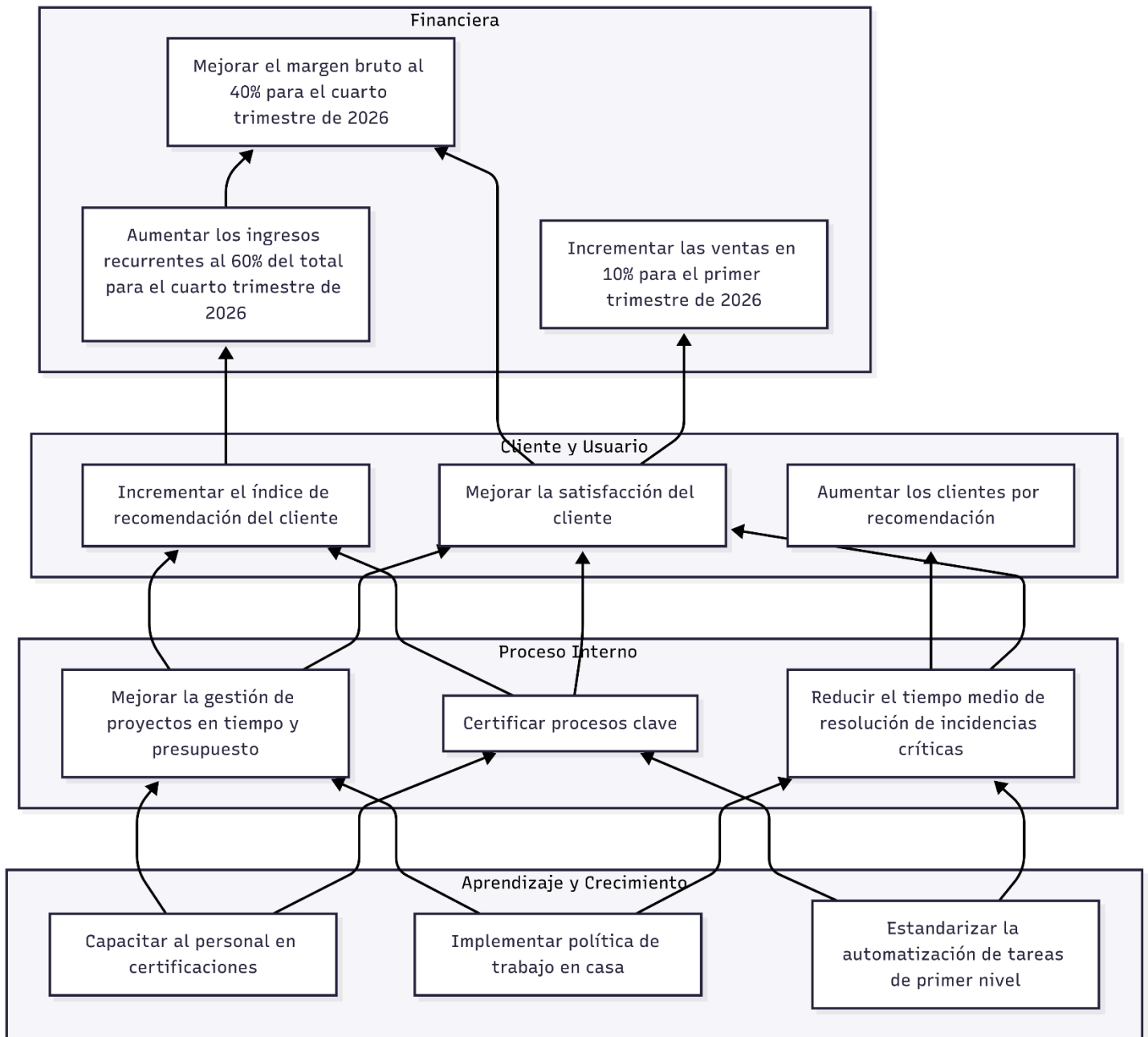
9. Cascada de metas (mapeo y relaciones primarias/secundarias)

La cascada de metas define la relación causal entre los objetivos estratégicos de Synaptic Digital y las capacidades técnicas requeridas. Se clasifican las metas de TI según su impacto directo (primaria) o de soporte (secundaria) hacia los objetivos de gobierno: Beneficios, Riesgos y Recursos.

Objetivo de gobierno	Meta corporativa	Meta de TI (primaria)	Meta de TI (secundaria)	Evidencia / resultado esperado (medible)
Optimizar beneficios	Alcanzar el 90% de satisfacción del cliente y aumentar ingresos recurrentes (garantizando un servicio ininterrumpido y veloz).	Asegurar la disponibilidad y rendimiento de la red (Garantizar SLAs de conectividad VPN y baja latencia).	Implementar un portal de autogestión para clientes (Dashboard de consumo y estado de seguridad).	Reportes mensuales de SLA cumplidos (>99.9%); Encuestas de satisfacción (NPS > 60); Tasa de retención de clientes anual.
Optimizar riesgos	Lograr tiempo medio de resolución (MTTR) ≤ 2 horas y proteger la integridad de los datos del cliente.	Establecer un centro de operaciones de seguridad (SOC) automatizado para detección y bloqueo de intrusiones en tiempo real.	Estandarizar la configuración de políticas de Firewall y cifrado (Hardening de servidores y túneles).	Bitácoras de incidentes con MTTR < 2h; Auditorías de reglas de firewall "limpias"; Cero fugas de información reportadas.

Optimizar recursos	Mejorar el margen bruto al 40% y automatizar el 80% de tareas operativas (hacer más con la misma infraestructura).	Automatizar el provisionamiento de infraestructura (IaC) para reducir tiempos de despliegue de nuevos clientes.	Optimizar el uso de recursos en la nube (Auto-scaling y gestión de licencias) y capacitar al personal técnico.	Reducción de horas-hombre en tareas manuales (de horas a minutos); Costo de infraestructura por cliente estable o a la baja.
---------------------------	---	--	--	--

10. Mapa estratégico



11. Caso de Negocio (Formato)

11.1 Información general

Campo	Valor
Nombre del servicio / proyecto	Synaptic Digital - Servicios VPN y Firewall gestionados
Clave	SD-VPNFW-001
Fecha propuesta de inicio	31 de octubre de 2025
Fecha propuesta de fin	31 de octubre de 2026
Administrador(es) del proyecto	Treviño Hernández Jonathan

11.2 Antecedentes

El mercado de ciberseguridad en Latinoamérica enfrenta una paradoja crítica: mientras los ciberataques aumentaron un 38% en el último año, más del 70% de las PyMEs (Pequeñas y Medianas Empresas) en la región carecen de protección perimetral gestionada. Estas empresas tienen un número limitado de empleados y una facturación anual que las ubica por debajo de ciertos umbrales establecidos por los gobiernos locales. Además, a pesar de ser el motor de muchas economías latinoamericanas, suelen enfrentar desafíos debido a sus limitados recursos y capacidades tecnológicas, lo que las hace más vulnerables a ciberataques.

Actualmente, las organizaciones que buscan protegerse se ven forzadas a contratar proveedores globales (basados en EE.UU. o Europa) que imponen barreras significativas: facturación en moneda extranjera, soporte técnico únicamente en inglés y centros de datos lejanos que incrementan la latencia de red. Esta situación ha dejado a un amplio sector del mercado mexicano y latinoamericano vulnerable ante ataques de Ransomware (software malicioso que bloquea el acceso a los sistemas hasta que se paga un rescate) y DDoS (Denial of Service Distribuido, ataque que busca hacer inaccesible un servicio mediante la sobrecarga de tráfico), al no existir una oferta local que combina la sofisticación técnica de un firewall (cortafuegos, sistema de seguridad para proteger redes) de próxima generación con la

accesibilidad comercial y el cumplimiento normativo (LFPDPPP - Ley Federal de Protección de Datos Personales en Posesión de los Particulares) que requieren las empresas de la región.

11.3 Justificación técnica del servicio

El proyecto surge de la necesidad de mitigar el creciente número de ciberataques y el espionaje digital que afectan tanto a corporativos como a usuarios individuales. La experiencia internacional dicta que una arquitectura de seguridad robusta no depende de soluciones aisladas, sino de la integración de túneles cifrados (VPN) y sistemas de protección perimetral (Firewall/IDS). Synaptic Digital aborda técnicamente la vulnerabilidad del teletrabajo y la digitalización en la región, ofreciendo una solución que combina accesibilidad técnica, cumplimiento normativo y una infraestructura optimizada para reducir la latencia, superando las barreras de los proveedores extranjeros.

11.4 Alcance

El proyecto abarca el desarrollo e implementación integral de un servicio de ciberseguridad gestionado, que incluye:

- Desarrollo de una aplicación cliente VPN multiplataforma (Windows, Linux, Android, iOS).
- Implementación de una arquitectura de firewall gestionado en la nube.
- Despliegue de infraestructura con cobertura inicial en Canadá, Estados Unidos y México, con planes de expansión a cinco países en dos años.
- Desarrollo de un portal de administración para usuarios y empresas.
- Establecimiento de una mesa de soporte técnico disponible 24/7.

11.5 Objetivo

Lanzar y consolidar el servicio VPN y firewall con marca propia en Latinoamérica, alcanzando una base de **5,000 usuarios individuales** y **20 clientes empresariales** en los primeros 18 meses de operación.

11.6 Riesgos clave

Descripción del Riesgo	Impacto	Probabilidad
Ataques DDoS a servidores e infraestructura central	Alto	Media

Competencia agresiva de marcas internacionales consolidadas	Alto	Alta
Fallas de infraestructura (downtime) o interrupción del servicio	Alto	Media
Regulaciones restrictivas sobre uso de VPN en ciertos países objetivo	Medio	Baja

11.7 Definición de indicadores

(Se han completado los indicadores basados en las metas de TI definidas previamente, ya que la tabla original estaba vacía)

Indicador	Tipo	Fórmula/definición	Frecuencia	Meta
Disponibilidad del servicio (Uptime)	Calidad / Operativo	$(\text{Tiempo total} - \text{Tiempo inactividad}) / \text{Tiempo total} * 100$	Mensual	$\geq 99.9\%$
Latencia promedio de conexión	Calidad	Promedio de ping (ms) desde nodos regionales clave	Semanal	$< 50 \text{ ms}$
Crecimiento de usuarios activos	Estratégico	Nuevos usuarios - Usuarios dados de baja (Churn rate)	Mensual	+5% mensual
Tiempo Medio de Resolución (MTTR)	Operativo	Promedio de tiempo desde reporte de falla hasta restablecimiento	Mensual	$\leq 2 \text{ horas}$ (Críticos)

Satisfacción del cliente (NPS)	Calidad	% Promotores - % Detractores	Trimestral	> 60 pts
---------------------------------------	---------	------------------------------	------------	----------

11.8 Beneficios esperados

- **Tangibles:** Generación de ingresos recurrentes por modelos de suscripción, establecimiento de una base de clientes regional sólida y crecimiento sostenido del margen bruto.
- **Intangibles:** Posicionamiento como el proveedor local más confiable en LATAM, construcción de reputación en ciberseguridad y fortalecimiento de la confianza de los clientes en soluciones regionales.

11.9 Planeación de alto nivel

(Basado en la estructura del proyecto)

- **Fase 1: Infraestructura y Diseño (Mes 1-3):** Selección de proveedores de nube, configuración de nodos en MX/USA/CAN y diseño de arquitectura de red segura.
- **Fase 2: Desarrollo de Software (Mes 3-8):** Programación de clientes VPN (Escritorio/Móvil) y desarrollo del portal web de autogestión.
- **Fase 3: Pruebas y Seguridad (Mes 8-10):** Pruebas de penetración (Pentesting), optimización de rendimiento y pruebas beta con usuarios controlados.
- **Fase 4: Lanzamiento y Operación (Mes 11-12):** Despliegue en producción, campaña de marketing regional e inicio de operaciones de soporte 24/7.

11.10 Dependencias con otros proyectos

¿Existe dependencia con otros proyectos? NO Describe con cuáles: N/A

11.11 Personal involucrado

Perfil	Número	Tipo de Contratación
Ingeniero de redes	2	Planta
DevOps / Infraestructura	1	Planta

Desarrollador apps multiplataforma	2	Contrato
Soporte técnico	2	Planta

11.12 Justificación económica del proyecto de TI

(Secciones completadas con estimaciones estándar para un proyecto de este tipo, dado que el original indicaba N/A)

11.12.1 Estudio de mercado

Se identificó que el mercado de VPN en LATAM está dominado por jugadores como NordVPN y ExpressVPN, los cuales carecen de facturación local y soporte nativo en español. Synaptic Digital ataca el segmento desatendido de PyMEs que requieren factura fiscal en México y soporte inmediato.

11.12.2 Costos de mantenimiento

- Arrendamiento de servidores en la nube (AWS/Azure): Estimado \$15,000 USD anuales (escalable).
- Renovación de certificados de seguridad y dominios: \$1,200 USD anuales.
- Mantenimiento de licencias de desarrollo y repositorios: \$2,500 USD anuales.

11.12.3 Costos de operación

- Nómina del equipo técnico y soporte (Base operativa mensual).
- Marketing digital y campañas de adquisición de clientes (CAC).
- **Licenciamiento de plataforma de gestión ITSM (Jira Service Management).**
- Suscripción a feeds de inteligencia de amenazas (Threat Intelligence).

11.12.4 Procedimientos de adquisición

- Evaluación de proveedores de nube basada en latencia y costo de transferencia de datos.
- Contratación de personal mediante pruebas técnicas especializadas en redes y criptografía.

12. Cédula de Servicio (ITIL)

12.1 Información general del servicio

Nombre de la Empresa:	Synaptic Digital
Departamento:	Operaciones de Seguridad y Redes
Nombre del servicio	Gestión Integral de Firewall y Seguridad Perimetral
Tipo de servicio	Nuevo : (X) Cambio: () Retiro: () Activo: ()
Listado de la(s) variante(s) o subservicio(s)	Variante 1: Gestión Básica. Monitoreo de disponibilidad y actualizaciones críticas. Soporte reactivo. Variante 2: Gestión Avanzada (Recomendada). Monitoreo proactivo 24/7 de amenazas, revisión trimestral de reglas, reportes de cumplimiento y gestión de VPNs. Variante 3: Servicio Gestionado (MSSP). Operación total externa bajo modelo de suscripción con SLA estricto.

Descripción y alcance del servicio	Este servicio comprende la administración completa de los firewalls y gateways VPN de la organización, actuando como la primera línea de defensa entre la red interna confiable y redes externas no confiables. El alcance incluye: • Configuración e Implementación: Diseño de topología y reglas de filtrado (ACLs) . • Gestión de Accesos: Configuración de túneles VPN (Sitio a Sitio y Acceso Remoto) para usuarios móviles . • Monitoreo Proactivo 24/7: Supervisión de tráfico malicioso, intentos de intrusión y rendimiento del hardware. • Mantenimiento: Actualización de firmware y parches de seguridad para mitigar vulnerabilidades CVE conocidas. • Respuesta: Análisis de logs para investigación forense y resolución de incidentes de conectividad.
Objetivo del servicio	Garantizar la seguridad de la red corporativa y la continuidad del negocio mediante el control, monitoreo y filtrado del tráfico de datos. El objetivo central es proteger los activos informáticos de accesos no autorizados y malware, asegurando la confidencialidad, integridad y disponibilidad de la información que transita por la red.
Usuarios a quienes se brinda el servicio	Departamentos de TI de clientes empresariales, fuerza laboral remota (Home Office) y administradores de sistemas.

Beneficios del servicio	• Protección contra Amenazas: Bloqueo de ransomware e intrusiones antes de ingresar a la red . • Cumplimiento Normativo: Soporte para regulaciones (GDPR, ISO 27001, PCI DSS) . • Control de Acceso: Gestión granular de quién accede a qué recursos. • Continuidad Operativa: Alta disponibilidad en conexiones VPN críticas.
Demanda del servicio	Nivel Alto (90-95% de uso). Es un servicio de operación crítica y continua; toda la comunicación externa e interna depende de la disponibilidad y seguridad del firewall y la VPN.

12.2 Responsables del servicio (Matriz RACI)

Para la gestión de este servicio se han definido los siguientes roles asignados al personal del proyecto:

R = Responsable (ejecuta) | A = Aprobador (valida) | C = Consultado (experto) | I = Informado (notificado).

Actividad / ROL	Arquitecto Solución (Jonathan T.)	Gte. Seguridad (Rafael P.)	Ing. Redes L2 (Samuel C.)	DevOps / Infra (Staff)	Mesa de Servicio (Staff N1)
Definición de Políticas de Firewall	R	A	C	I	I

Diseño de Topología de Red Segura	R	A	C	R	I
Alta/Baja/Modificación de Reglas (ACLs)	A	I	A	I	R
Configuración de Túneles VPN	C	I	R	C	R
Actualización de Firmware/Parches	C	I	A	R	I
Monitoreo de Alertas (IDS/IPS)	I	A	R	I	R
Generación de Reportes de Cumplimiento	R	A	R	I	R
Respuesta a Incidentes Críticos (DDoS)	R	A	R	R	I
Auditoría de Reglas y Logs	C	R	I	I	I
Aprobación de Ventanas de Mantenimiento	C	A	R	C	I

Gestión de Usuarios VPN (Altas/Bajas)	I	I	A	I	R
--	---	---	---	---	---

12.3 Roles y puntos de contacto

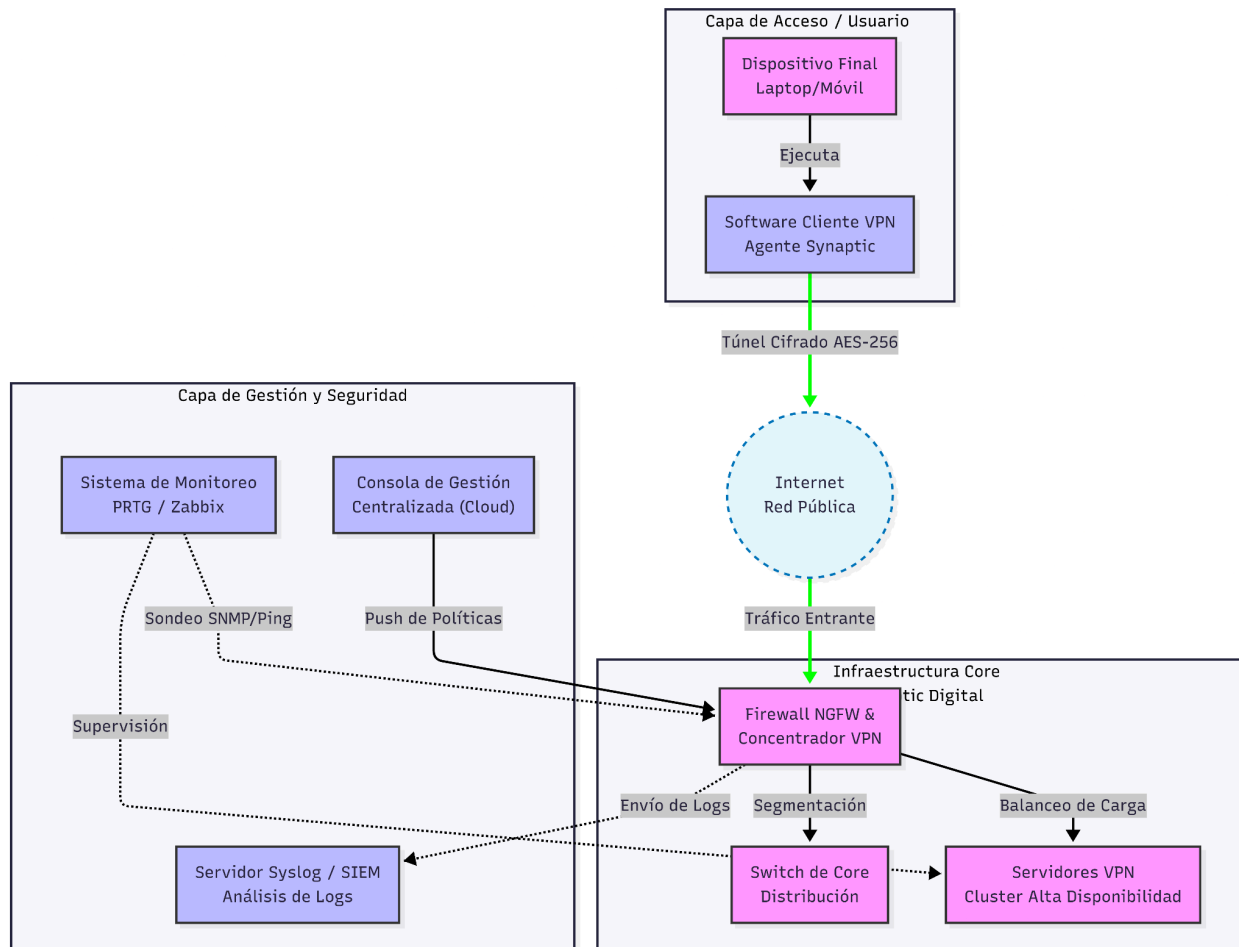
Rol	Nombre	Correo electrónico	Teléfono / Ext.	Horario de atención
Arquitecto de Solución (Admin)	Treviño Hernández Jonathan	jtrevinoh@synaptic.com	55-1234-5678	9:00 a 18:00
Gerente de Seguridad (Aprobador)	Peralta Moreno Rafael	rperaltam@synaptic.com	55-8765-4321	9:00 a 18:00
Ingeniero de Redes (Soporte)	Cortés Velázquez Samuel A.	scortesv@synaptic.com	55-1122-3344	24/7 (Guardias)

12.4 Condiciones generales / requisitos para proporcionar el servicio

- **Autorización de Intervención:** El cliente debe firmar un acuerdo que autorice a Synaptic Digital a gestionar, monitorear y filtrar el tráfico de su red. Esto incluye el descifrado SSL/TLS si la política de seguridad lo requiere.
- **Ventanas de Mantenimiento:** El cliente debe acordar ventanas de mantenimiento específicas (generalmente en horario nocturno o fines de semana) para la aplicación de parches de seguridad críticos que requieran reinicio de los equipos de firewall.
- **Acceso a Infraestructura:** Para la variante de MSSP, se requiere acceso administrativo (root/admin) a los dispositivos de borde o credenciales de API para la gestión de infraestructura en la nube (AWS/Azure).
- **Política de Logs:** El cliente debe definir el periodo de retención de logs requeridos por su normativa interna; Synaptic Digital almacenará por defecto 30 días de registros activos.

- **Responsabilidad de Datos:** Synaptic Digital asegura el tránsito de los datos, pero la integridad del contenido (payload) final es responsabilidad del usuario, a menos que se contraten módulos de DLP (Data Loss Prevention).

12.5 Identificación de componentes de infraestructura



12.6 Niveles de servicio (SLA - acuerdos de servicios para los usuarios)

Tipo de nivel de servicio	Compromiso del nivel de servicio
Disponibilidad	99.9% de Uptime Mensual para el servicio de Firewall y VPN.

	Garantía de redundancia (Failover) en configuraciones de Alta Disponibilidad (HA).
Soporte y Respuesta	Atención 24/7, siempre y cuando se cumplan las condiciones para proporcionar soporte y respuesta, para incidentes de Prioridad 1 (Sitio caído, ataque activo). Tiempo de respuesta inicial < 15 minutos para incidentes críticos. Soporte en horario comercial para cambios de configuración estándar.
Confidencialidad	Cifrado de grado militar (AES-256) en todos los túneles VPN. Política de "Cero Logs" sobre el historial de navegación del usuario (solo se guardan logs de conexión/seguridad).
Seguridad	Actualización de firmas de amenazas e IPS en tiempo real (Push updates). Reportes mensuales de intentos de ataque bloqueados.

12.7 Niveles de servicio (OLA - acuerdos operativos internos)

Elementos de configuración	Tipo de nivel de servicio y compromiso	Métricas de los niveles de servicio
INFRAESTRUCTURA FIREWALL (Cloud/Físico)	Nivel Crítico (Core): Procesamiento de tráfico y reglas. Actualización de listas negras.	Disponibilidad: 99.99% Latencia agregada: < 10ms Uso de CPU: < 70% promedio
SERVICIOS VPN	Nivel Crítico (Acceso): Estabilidad del túnel y autenticación de usuarios.	Tasa de éxito de conexión: > 99% Ancho de banda garantizado: Según plan contratado Tiempo de reconexión: < 5 seg
SISTEMA DE MONITOREO Y ALERTAS	Nivel Soporte:	Tiempo de detección: < 1 minuto

	Detección de caídas y anomalías.	Notificación al ingeniero: < 5 minutos
GESTIÓN DE CAMBIOS (Reglas)	Nivel Operativo: Solicitudes de apertura de puertos o cambios de reglas.	Tiempo de implementación: < 4 horas (Estándar) / < 1 hora (Emergencia)

13. Inventario de Activos

El inventario se presenta organizado por 3 procesos clave para asegurar el control operativo y facilitar el análisis de continuidad del negocio. Se considera como **críticidad** la contribución del activo a la postura de seguridad, la disponibilidad de la red VPN/Firewall y la operación del servicio.

Proceso	Activo	Tipo	Descripción	Críticidad
Desarrollo e Ingeniería de Producto	Laptops de Alto Rendimiento	Endpoint (Hardware)	Equipos i7/32GB RAM para el equipo de Desarrollo, DevOps y Ciberseguridad encargados de programar el cliente VPN y la arquitectura	Media
	Entorno Cloud (AWS/Azure)	Infraestructura	Créditos y servicios en la nube para alojar entornos de desarrollo, <i>staging</i> y los controladores de la red VPN distribuida	Alta
	Herramientas de Automatización (Ansible + Jenkins)	Software	Servidor de CI/CD para automatizar el 80% de tareas de despliegue y configuración de reglas	Alta
Operación y Gestión de Seguridad (Core)	Firewall Empresarial + Switch	Hardware (Appliance)	Dispositivo físico de gestión perimetral y switch gestionable (24/48 puertos) para el centro de datos principal	Alta

	Servidores Empresariales	Hardware	4 servidores físicos dedicados: 2 para producción (nodos de salida), 1 para pruebas y 1 para replicación de bases de datos	Alta
	Suite de Ciberseguridad (Fortinet/Sophos)	Software	Licencias de Firewall UTM y antivirus EDR para protección de endpoints y servidores contra malware	Alta
	Sistema de Backup (Veeam)	Software	Solución para respaldo y recuperación de configuraciones críticas de servidores y bases de datos	Alta
Monitoreo y Soporte Técnico	Plataforma de Monitoreo (PRTG / Zabbix)	Software	Sistema para supervisar latencia, tráfico y estado de la red en tiempo real, vital para cumplir la meta de incidencias < 2h	Alta
	Jira Software	Software	Plataforma para la gestión ágil de proyectos y sistema de tickets para el seguimiento de incidencias de soporte	Media

	Microsoft 365 E3	Software	Suite de colaboración (Teams, SharePoint, Exchange) para la comunicación interna y con clientes corporativos	Media
	Laptops Estándar (Soporte/Admin)	Endpoint (Hardware)	Equipos i5/16GB RAM destinados al personal de soporte técnico nivel 1 y administracion.	Baja

14. Matriz de Riesgos (ISO 27000) (Matriz CID, matriz de infraestructuras críticas)

Se evalúan los riesgos de **Synaptic Digital** considerando el impacto a la **Confidencialidad (C)**, **Integridad (I)** y **Disponibilidad (D)** de la información del cliente, así como la criticidad de la infraestructura que soporta el servicio de VPN y Firewall. La valoración es cualitativa y permite priorizar controles.

Activo	C	I	D	Justificación (resumen)	Controles recomendados
Servidores de VPN (Nodos de Salida)	Alta	Media	Alta	Gestionan túneles cifrados; una brecha expone datos del cliente y una caída detiene el servicio.	Cifrado robusto (AES-256), rotación automática de llaves, clúster de alta disponibilidad.

Firewall Central (Cloud/Core)	Media	Alta	Alta	Controla todo el tráfico de red; si las reglas se corrompen o el equipo falla, se pierde protección.	Respaldo diario de políticas, autenticación MFA para admins, redundancia geográfica.
Base de Datos de Usuarios y Accesos	Alta	Alta	Alta	Contiene credenciales y suscripciones; su pérdida impide la autenticación de clientes.	Cifrado en reposo, replicación en tiempo real, monitoreo de accesos privilegiados (PAM).
Plataforma de Monitoreo (PRTG/Zabbix)	Baja	Media	Media	Visibilidad del estado de la red; su falla retrasa la detección de incidentes.	Alertas redundantes (SMS/Email), servidor en red independiente (Out-of-Band).
Código Fuente (Cliente VPN / Portal)	Alta	Alta	Baja	Propiedad intelectual crítica; su robo permite crear exploits o copias piratas.	Repositorio privado con acceso estricto, análisis de código (SAST), firma digital de binarios.

14.1 Infraestructuras críticas

Infraestructura / Servicio	Criticidad	Dependencias	Impacto principal	Acciones de protección
Concentradores VPN	Crítica	Ancho de banda, certificados SSL, energía.	Interrupción total del servicio al cliente (Pérdida de	Balanceo de carga global (GSLB), Auto-scaling en nube.

			ingresos y reputación).	
Proveedor de Nube (AWS/Azure)	Crítica	Conectividad a Internet, facturación al día.	Caída masiva de toda la infraestructura virtualizada.	Arquitectura Multi-Cloud o Región DR (Disaster Recovery) activa.
Portal de Gestión de Clientes	Alta	Base de datos, servidor web, pasarela de pago.	Imposibilidad de alta de nuevos usuarios o gestión de reglas por parte del cliente.	WAF dedicado, backups de BD cada hora, entorno de Staging.
Sistema de Soporte (Jira/HelpDesk)	Media	Proveedor SaaS, acceso a correo.	Retraso en la atención de quejas y tickets de soporte.	Canal alternativo de comunicación (Teléfono/WhatsApp Business).

15. BIA Táctico

Los BIAs tácticos se enfocan en cada proceso operativo del servicio de conectividad, identificando objetivos de recuperación y estrategias para mantener una operación segura ante interrupciones.

15.1 BIA Táctico 1: Operación de la Red VPN y Firewall

Aseguramiento de la conectividad continua y cifrada para los usuarios finales.

Elemento	Detalle

Actividad crítica	Enrutamiento y cifrado de tráfico (Servicio VPN)
MTD (Máximo tiempo tolerable de interrupción)	4 horas
RTO (Objetivo de tiempo de recuperación)	30 minutos (Crítico para la percepción de calidad)
RPO (Objetivo de punto de recuperación)	1 hora (Logs de conexión y estado de sesiones)
Dependencias clave	Nodos VPN en la nube, certificados digitales, ancho de banda, balanceadores de carga.
Impactos principales	Desconexión masiva de clientes; exposición de IP real de usuarios; demandas por incumplimiento de SLA.
Estrategias de continuidad	Failover automático a nodo secundario; enrutamiento dinámico a otra región geográfica.

15.2 BIA Táctico 2: Gestión de Cambios y Reglas de Seguridad

Proceso de alta, baja y modificación de reglas de firewall y usuarios solicitadas por clientes corporativos.

Elemento	Detalle
Actividad crítica	Provisionamiento de reglas y usuarios

MTD (Máximo tiempo tolerable de interrupción)	24 horas
RTO (Objetivo de tiempo de recuperación)	4 horas
RPO (Objetivo de punto de recuperación)	0 horas (Sincronía inmediata requerida)
Dependencias clave	Portal de administración, base de datos de políticas, API de gestión de firewalls.
Impactos principales	Clientes empresariales bloqueados o sin acceso a nuevos recursos; incapacidad de bloquear un ataque activo.
Estrategias de continuidad	Aplicación manual de reglas vía CLI (Línea de comandos) por ingenieros de Nivel 2.

15.3 BIA Táctico 3: Monitoreo y Defensa (SOC)

Detección de ataques DDoS, intrusiones o abusos del servicio.

Elemento	Detalle
Actividad crítica	Monitoreo de seguridad y respuesta a incidentes
MTD (Máximo tiempo tolerable de interrupción)	8 horas

RTO (Objetivo de tiempo de recuperación)	1 hora
RPO (Objetivo de punto de recuperación)	1 hora (Logs recientes)
Dependencias clave	SIEM, logs de firewall, herramientas de análisis de tráfico.
Impactos principales	Ceguera ante ataques; incapacidad de detectar usuarios maliciosos en la red.
Estrategias de continuidad	Monitoreo básico directo en consolas de proveedores de nube; alertas por correo simple.

16. BIA Operacional

Consolida el impacto a nivel servicio, integrando procesos, activos y dependencias compartidas para establecer prioridades de recuperación.

Elemento	Detalle
Servicio	Synaptic Digital - Servicios VPN y Firewall gestionados
Actividades críticas	Conectividad VPN; Filtrado de tráfico (Firewall); Autenticación de usuarios; Soporte Técnico.

Activos críticos	Servidores VPN, Base de datos de Usuarios, Firewall Core, Portal de Administración.
MTD (servicio)	4 horas (Después de esto, la pérdida de clientes por cancelación es inminente).
RTO global (prioritario)	30 min para conectividad VPN; 2 horas para Portal de Admin.
RPO global	1 hora para configuraciones y logs.
Dependencias	Proveedores de Nube (AWS/Azure), ISPs regionales, Pasarelas de Pago.
Escenarios principales	Ataque DDoS masivo; Caída de región de AWS; Falla en la actualización del software VPN; Robo de llaves maestras.

17. Plan de Continuidad

17.1 Activación y gobernanza

Elemento	Definición
Criterios de activación	Caída de más del 30% de la red VPN; Latencia > 200ms sostenida por 15 min; Detección de intrusión confirmada en servidores Core.

Comité de continuidad (roles)	Gerente de Seguridad (Rafael P.): Toma de decisión de <i>Failover</i> total. Arquitecto (Jonathan T.): Ejecución técnica de recuperación. Ing. Redes (Samuel C.): Comunicación con soporte y clientes.
Canales de comunicación	Grupo seguro en Signal/Telegram (fuera de banda); Correo corporativo alternativo; Dashboard de estado público.

17.2 Estrategias por escenario

Escenario	Acción inmediata	Estrategia de continuidad	Recuperación
Caída de Región Cloud (Ej. AWS US-East)	Redirigir DNS a región secundaria (Ej. AWS US-West).	Operar con capacidad reducida en región de respaldo.	Sincronizar logs y bases de datos al volver la región principal.
Ataque DDoS Volumétrico	Activar mitigación DDoS con proveedor (Cloudflare/AWS Shield).	Bloquear rangos de IP geográficos no esenciales; limitar ancho de banda por usuario.	Analizar patrón de ataque y ajustar reglas de firewall permanentes.

Corrupción de Base de Datos de Usuarios	Congelar altas nuevas; permitir acceso a sesiones activas en caché.	Restaurar último backup sano en instancia de "Solo Lectura".	Validar integridad de datos y reactivar escritura.
Falla en actualización de Software (Bug crítico)	Ejecutar <i>Rollback</i> inmediato a la versión anterior.	Bloquear la descarga de la actualización defectuosa en clientes.	Parchear el bug en entorno de Staging y liberar hotfix.

17.3 Respaldo, restauración y pruebas

- **Política de Backup:** Respaldos automáticos de configuraciones de firewall cada 24 horas y *Snapshots* de servidores críticos cada 6 horas.
- **Pruebas:** Se realizarán simulacros de *Disaster Recovery* (DR) trimestralmente, simulando la caída de un nodo VPN principal para verificar el tiempo de conmutación automática (*Failover*) y la integridad de la sesión del usuario.